

NETWORK WALKS

Penetration Test Report

Mediroza General Hospital

Black-Box Web Application Penetration Test

Prepared by: Desrine Harripaul

Date: 11 September 2026

Batch: B082 | **Week:** 4

Client	Mediroza General Hospital
Target	https://medirozahospital.com
Assessment	Black-box penetration test
Environment	Controlled educational lab
Duration	3 days

CONFIDENTIAL – LAB ASSESSMENT

1. Executive Summary

A black-box penetration test was performed against the Mediroza General Hospital web application within the authorized Network Walks Week 4 laboratory environment. The assessment followed the project milestones of initial access, data extraction, critical data exposure, and reporting.

The assessment demonstrated a complete attack chain from web-accessible confidential patient laboratory reports to weak PDF protection, metadata disclosure, and an exposed database backup. The backup contained sensitive organizational information, including employee salary records and shareholder information.

The most significant issue was the exposure of a database backup through the publicly reachable /old/ directory. This materially increased the impact of the initial web exposure because a single accessible backup provided a much broader dataset than the individual patient reports.

Overall Risk	Patient Data	Corporate Data	Attack Chain
CRITICAL	CRITICAL	CRITICAL	HIGH

Key outcomes

- Three confidential patient PDF laboratory reports were successfully obtained.
- PDF password protection was shown to be weak/predictable through successful dictionary-style password matches.
- Recovered PDF content was successfully opened/decrypted.
- PDF metadata exposed j.malik and a comment referencing a database backup in /old/.
- The /old/ directory exposed mediroza_db_backup_2019.sql for direct download.
- The database backup contained staff salary data and shareholder information.
- The staff table correlated j.malik with Jameel Malik, an IT Systems Administrator.

2. Scope and Rules of Engagement

The assessment was conducted as a full black-box penetration test against the agreed target domain medirozahospital.com in a controlled educational environment. The project authorized testing within the target and excluded social engineering, denial-of-service activity, and testing outside the agreed scope.

Item	Details
In scope	The Mediroza General Hospital website and its web-exposed resources under the target domain.
Out of scope	Social engineering and denial-of-service testing, and testing outside the agreed target.
Approach	Black-box testing with no assumed internal knowledge.
Objective	Demonstrate initial access, recover three confidential patient PDFs, defeat their encryption, and identify the critical data.

3. Methodology and Tools

- **Reconnaissance / web enumeration:** Reviewed exposed web resources and application behavior; used curl and a web browser.
- **Initial access / data retrieval:** Accessed the patient-report functionality and obtained three confidential PDF files.
- **Password analysis:** Used the lab's PDF cracking workflow to test candidate passwords and confirm successful matches.
- **Decryption:** Used qpdf to decrypt a recovered PDF after obtaining a valid password.
- **Metadata analysis:** Used exiftool to inspect document properties and identify the /old backup clue.

- **Server-side exposure:** Requested /old/ and observed directory indexing with a downloadable SQL backup.
- **Database analysis:** Inspected the recovered SQL backup and correlated staff and shareholder records.

4. Findings and Proof of Exploitation

F-01 — Confidential patient reports exposed through the web application

Severity: **CRITICAL**

Three confidential pathology laboratory-report PDFs were successfully obtained. The screenshots show the files patient_report_1.pdf, patient_report_2.pdf, and patient_report_3.pdf present in the tester's download location.

Recommended remediation: Restrict report retrieval to the requesting patient/authorized role; enforce server-side authorization on every report request; use non-guessable object references; log and alert on abnormal report access.

F-02 — Weak / predictable PDF password protection

Severity: **HIGH**

The PDF cracking exercise produced successful password matches. Evidence includes successful matches for common candidate passwords shown by the cracking interface. A recovered PDF was then opened/decrypted successfully.

Recommended remediation: Do not rely on simple human-readable passwords for confidential documents. Use strong, randomly generated per-document keys where encryption is required, or deliver documents through an authenticated portal with server-side access control.

F-03 — PDF metadata discloses internal information and an operational backup path

Severity: **HIGH**

Metadata analysis of a recovered report identified the author identifier j.malik and a comment stating that a database backup had been moved to /old/. The metadata also identified the Mediroza CMS/reporting components used to create the file.

Recommended remediation: Sanitize metadata before external delivery; remove internal usernames, comments, software/version information, and operational notes.

F-04 — Directory listing exposes database backup

Severity: **CRITICAL**

A request to /old/ returned a directory index containing mediroza_db_backup_2019.sql. The SQL backup was directly downloadable from the web server.

Recommended remediation: Remove backup files from web-accessible directories immediately; disable directory indexing; store backups outside the web root; apply deny rules and monitor for access to backup paths.

F-05 — Database backup exposes employee salary and shareholder information

Severity: **CRITICAL**

Inspection of the recovered SQL backup showed a staff table containing employee salary data and a shareholders table containing shareholder names, ownership percentages, and share classes. The staff dataset contained 30 employee records; the shareholder dataset contained 10 records.

Recommended remediation: Treat backups as highly sensitive assets. Encrypt backups at rest, restrict filesystem access, use dedicated backup storage, remove legacy backups from production web roots, rotate exposed credentials if present, and perform regular backup exposure audits.

5. Attack Chain Correlation

1. Web application access enabled retrieval of three confidential patient PDF reports.
2. The PDFs were protected by weak/predictable passwords that could be recovered through dictionary-style password testing.

3. After decryption, document metadata exposed the author identifier j.malik and an internal comment referencing a backup under /old/.
4. The /old/ web directory was browsable and exposed mediroza_db_backup_2019.sql.
5. The SQL backup contained staff and shareholder data, materially expanding the scope of information exposed.
6. The staff table correlated j.malik with Jameel Malik, an IT Systems Administrator, linking the metadata clue to the organizational record.

This chain demonstrates how a seemingly limited document exposure can become a broader compromise when sensitive metadata and legacy backups are left accessible from production infrastructure.

6. Business and Security Impact

- Patient confidentiality: unauthorized disclosure of pathology reports can expose highly sensitive personal and medical information.
- Privacy and compliance exposure: public exposure of patient data can create significant legal, regulatory, contractual, and reputational consequences.
- Employee confidentiality: salary records expose compensation information for personnel.
- Corporate confidentiality: shareholder records expose ownership structure and related business information.
- Attack enablement: internal usernames, software identifiers, operational comments, and backup locations provide useful information for further attacks.
- Blast radius: an exposed database backup can disclose significantly more information than the original web application entry point.

7. Recommendations and Remediation Plan

Priority	Action
Immediate – Remove exposed backup	Delete or relocate mediroza_db_backup_2019.sql from the web root and verify that /old/ and similar legacy paths are inaccessible.
Immediate – Disable directory indexing	Turn off directory listing on the web server and explicitly deny access to backup, archive, temporary, and migration directories.
Immediate – Protect patient reports	Enforce server-side authorization for every patient-report request and verify object-level access controls.
Immediate – Protect exposed data	Review whether any additional backups, exports, credentials, or datasets are exposed and rotate secrets if any are found.
Short term – Strengthen document protection	Replace predictable PDF passwords with strong, random, per-document protection where PDF encryption is used.
Short term – Sanitize metadata	Remove internal author identifiers, comments, file paths, software details, and other operational metadata from documents.
Short term – Secure backup architecture	Store backups in dedicated non-public storage with encryption, least-privilege access, retention controls, and audit logging.
Ongoing – Monitoring and testing	Add automated checks for web-accessible backup files, directory indexing, sensitive-data exposure, and authentication failures.

8. Evidence Register

ID	Evidence	Purpose
E-01	Three patient PDFs present in download directory	Shows successful acquisition of patient_report_1.pdf, patient_report_2.pdf and patient_report_3.pdf.
E-02	Successful PDF password match – 123456	Cracking interface displays a successful password match.
E-03	Recovered patient report – Sipho Dlamini	Opened confidential pathology report demonstrating readable protected content after access.
E-04	Successful PDF password match – password	Cracking interface displays a successful password match.
E-05	Recovered patient report – Priya Reddy	Opened confidential pathology report demonstrating additional patient data exposure.
E-06	Recovered patient report – Emily Thompson	Opened confidential pathology report and supports metadata-analysis workflow for the threat.

ID	Evidence	Purpose
E-07	Directory listing of /old/	Shows mediroza_db_backup_2019.sql exposed through a browsable web directory.

The screenshots contain sensitive patient information because they are direct lab evidence. They should be handled as confidential assessment artifacts and not distributed outside the authorized assessment/reporting context.

Appendix A – Technical Evidence

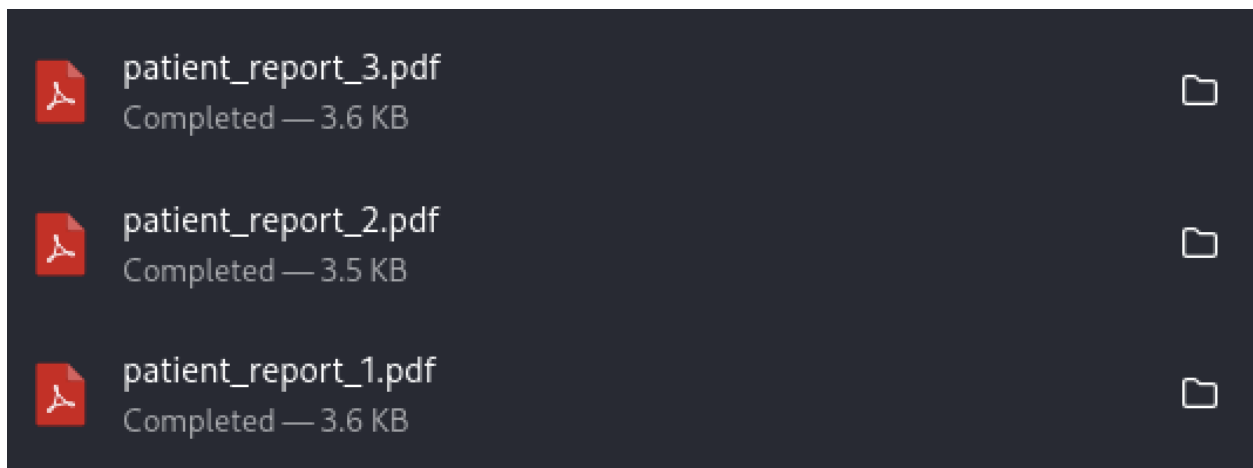


Figure A1. Three confidential patient PDF files successfully acquired.

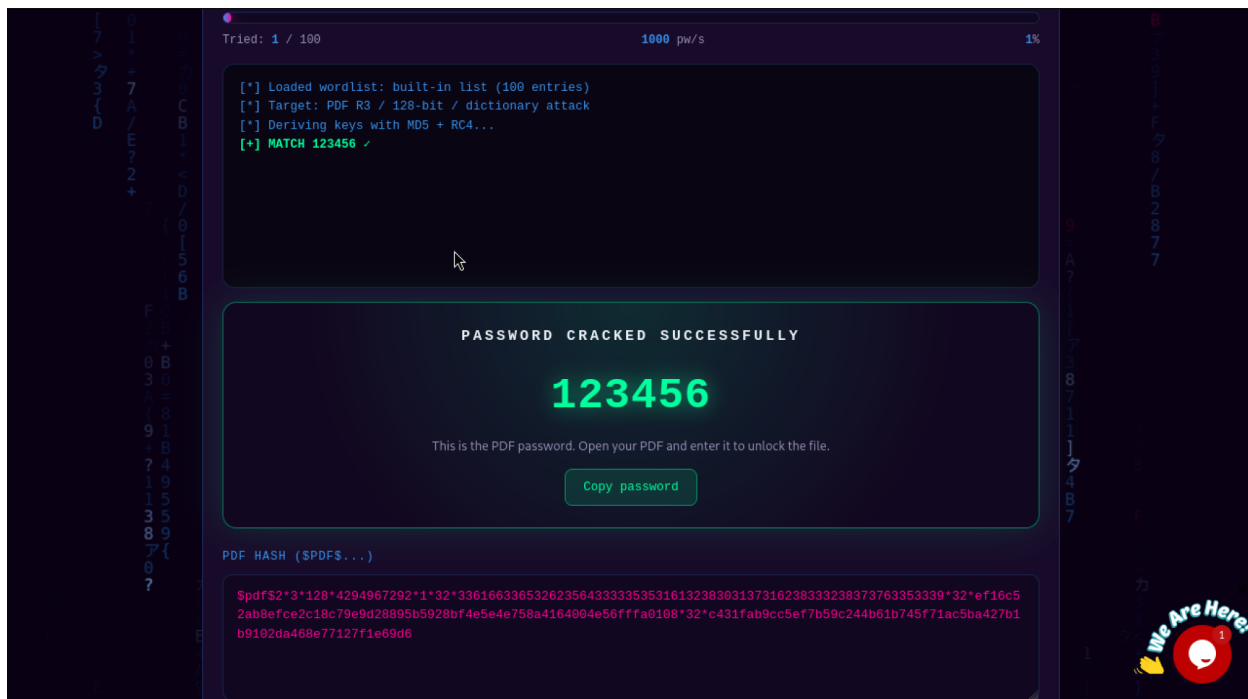


Figure A2. Successful password recovery for one protected PDF.

PATHOLOGY LABORATORY REPORT

CONFIDENTIAL

Patient Name: **Sipho Dlamini**

Report Date: **2024-11-04**

Patient ID: **MG-P-10231**

Referring Dr: **Dr. Anita Naicker**

Date of Birth: **1984-06-12**

Specimen: **Whole blood (EDTA)**

Gender: **Male**

Lab Ref No: **LR-2024-1187**

TEST	RESULT	UNIT	REFERENCE RANGE	FLAG
Haemoglobin	13.9	g/dL	13.0 - 17.0	Normal
White Cell Count	11.8	$\times 10^9/L$	4.0 - 11.0	HIGH
Platelet Count	245	$\times 10^9/L$	150 - 400	Normal
Fasting Glucose	5.4	mmol/L	3.9 - 5.5	Normal
Creatinine	88	umol/L	64 - 104	Normal

Figure A3. Recovered confidential pathology laboratory report.

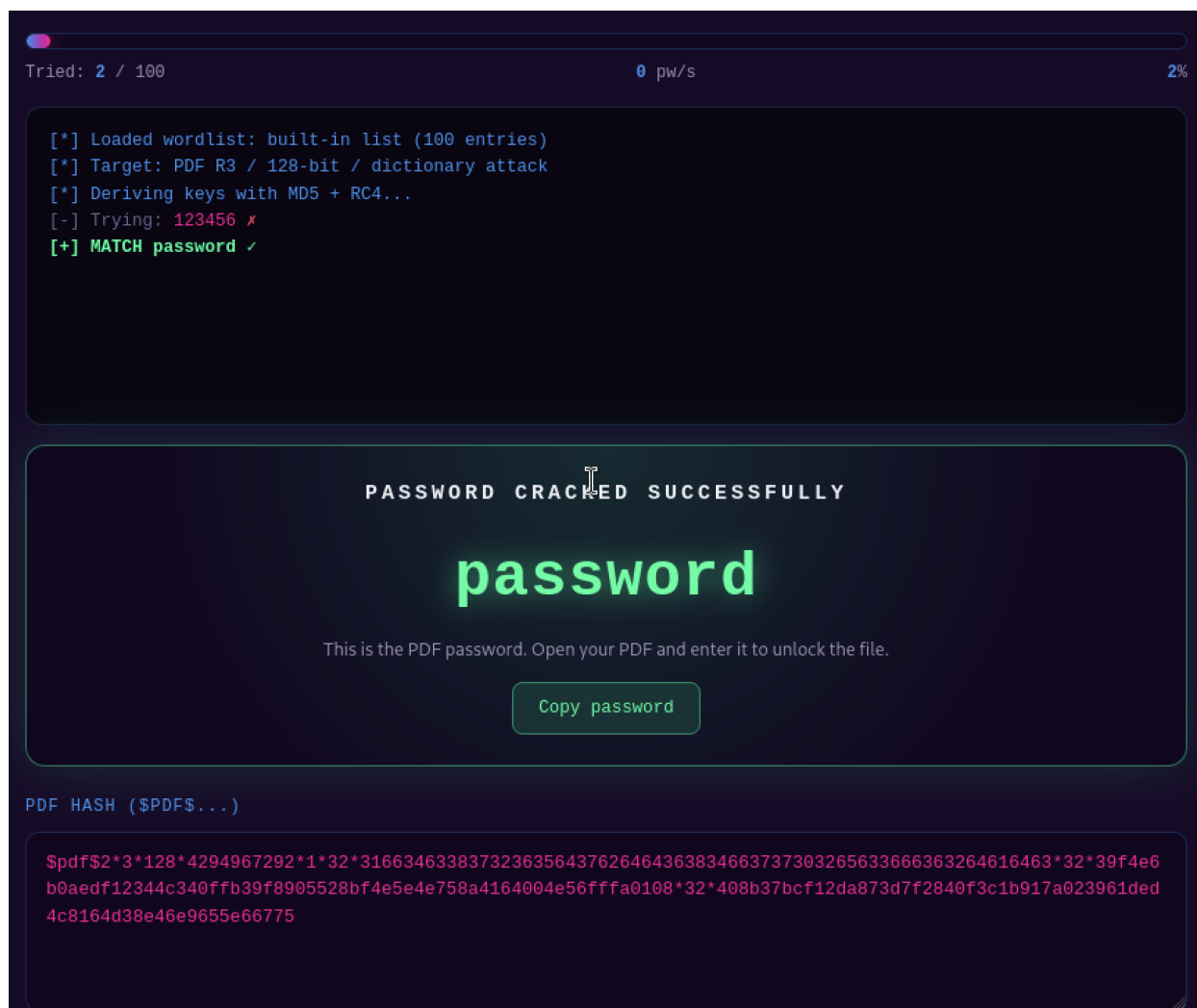


Figure A4. Successful password recovery for another protected PDF.

PATHOLOGY LABORATORY REPORT

CONFIDENTIAL

Patient Name: **Priya Reddy**
Patient ID: **MG-P-10244**
Date of Birth: **1991-02-28**
Gender: **Female**

Report Date: **2024-11-05**
Referring Dr: **Dr. Johan van der Merwe**
Specimen: **Serum**
Lab Ref No: **LR-2024-1192**

TEST	RESULT	UNIT	REFERENCE RANGE	FLAG
Total Cholesterol	6.4	mmol/L	< 5.0	HIGH
LDL Cholesterol	4.1	mmol/L	< 3.0	HIGH
HDL Cholesterol	1.2	mmol/L	> 1.0	Normal
Triglycerides	1.8	mmol/L	< 1.7	HIGH
Fasting Glucose	4.9	mmol/L	3.9 - 5.5	Normal

Figure A5. Recovered confidential pathology laboratory report.

PATHOLOGY LABORATORY REPORT

CONFIDENTIAL

Patient Name:	Emily Thompson	Report Date:	2024-11-06
Patient ID:	MG-P-10258	Referring Dr:	Dr. Ahmed Kara
Date of Birth:	1978-09-03	Specimen:	Serum
Gender:	Female	Lab Ref No:	LR-2024-1205

TEST	RESULT	UNIT	REFERENCE RANGE	FLAG
Haemoglobin	11.4	g/dL	12.0 - 15.5	LOW
Ferritin	9	ug/L	15 - 150	LOW
TSH	3.1	mIU/L	0.4 - 4.0	Normal
Vitamin D	42	nmol/L	50 - 125	LOW
Fasting Glucose	5.1	mmol/L	3.9 - 5.5	Normal

Figure A6. Recovered confidential pathology laboratory report.

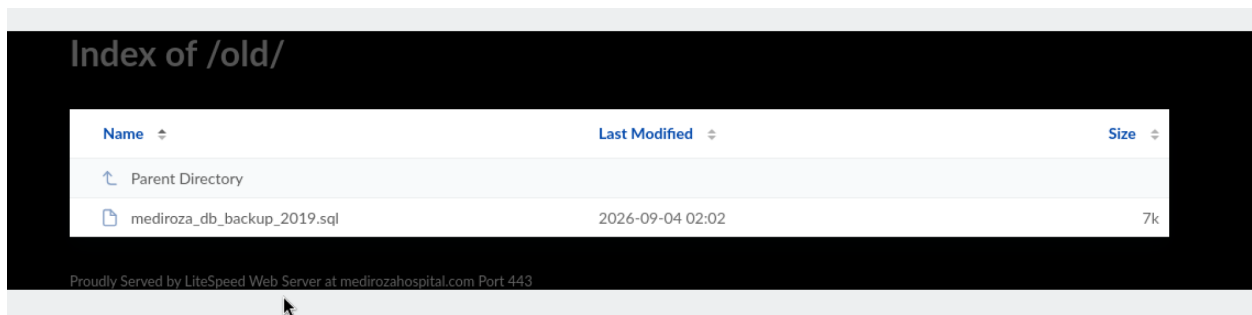


Figure A7. Publicly browsable /old/ directory exposing the SQL database backup.

Appendix B – Assessment Conclusion

The Mediroza General Hospital lab environment was shown to contain multiple weaknesses that combine into a high-impact attack path. The demonstrated sequence progressed from access to confidential patient reports, through weak document protection and metadata leakage, to direct exposure of a legacy database backup containing sensitive personnel and ownership information. Remediation should prioritize removal of publicly accessible backups and enforcement of server-side authorization for patient records.